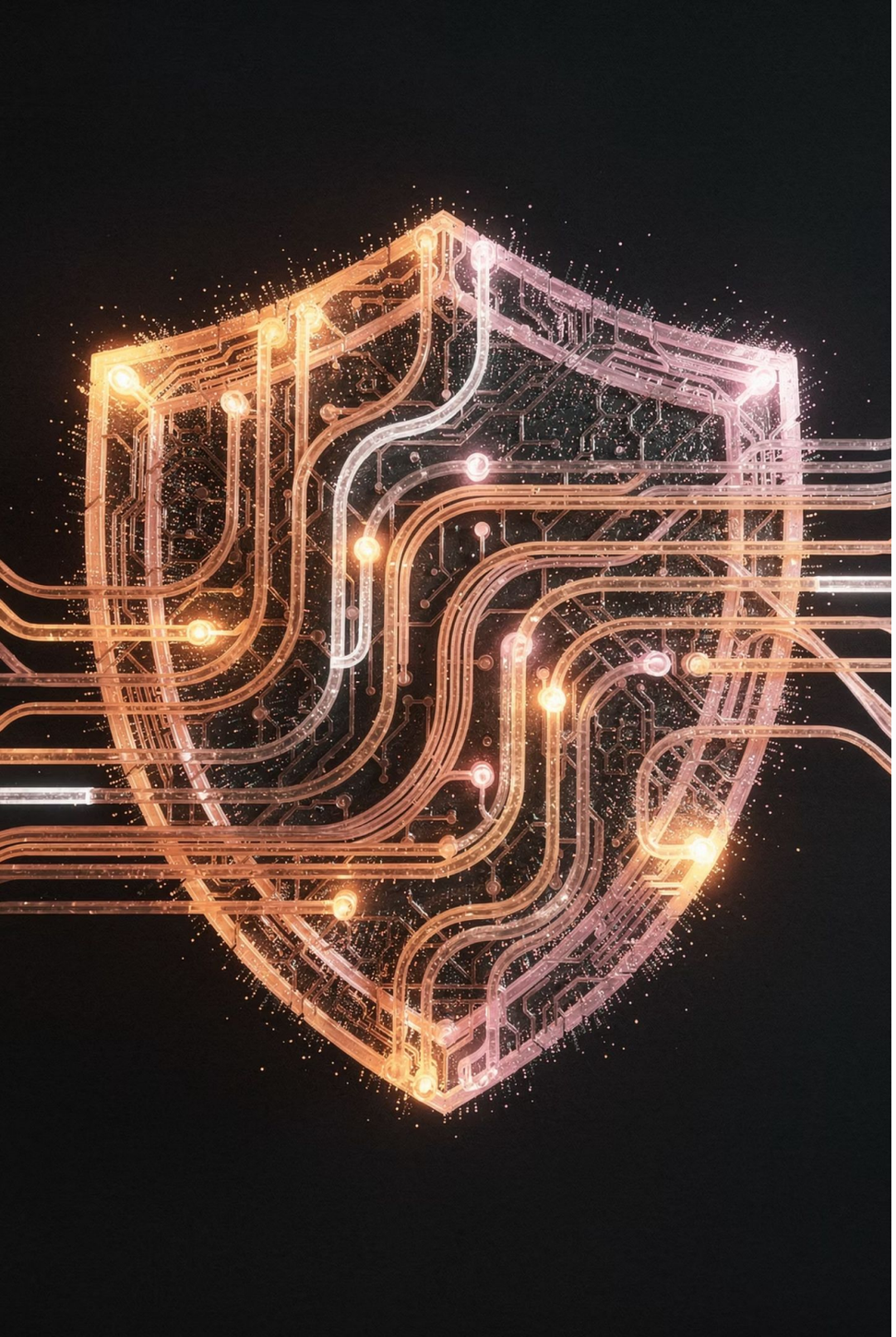

SECTION 2.2.2

Model Specific Controls

Model-specific controls are the security layer applied directly to an AI model governing its behavior, enforcing ethical boundaries, and ensuring compliance across its operational lifecycle. From input filtering to adversarial testing, these controls form the frontline defense of responsible AI deployment.

MODEL EVALUATION

On-Premise Model Evaluation

Evaluation methodology varies significantly based on how and where a model is deployed. On-premise models afford the highest degree of organizational control, enabling deep inspection of training pipelines and data provenance.

Deployment-Driven Evaluation

Whether a model is on-premise, pre-trained, or vendor-delivered determines the depth and focus of its security evaluation. Each deployment type carries distinct risk surfaces.

On-Premise: Full Visibility

Organizations retaining full infrastructure control can evaluate data lineage end-to-end, audit training data quality, and validate that security controls are embedded at every layer of the model stack.

Open-Source & Community Models

Pre-trained and community-shared models require careful scrutiny of training data integrity, potential bias introduced at the source, and explicit confirmation that the model's behavior aligns with internal governance policies.

MODEL EVALUATION

Vendor-Provided Model Evaluation

When organizations cannot directly inspect a model's training data or architecture, external assurances become the primary evidence base. Auditing vendor-provided documentation is essential to establish trust and verify security posture.

SOC 2 Certifications

Review vendor SOC 2 Type II reports for evidence of operational security controls, availability commitments, and data confidentiality practices.

Third-Party Pentest Reports

Assess results from independent penetration testing to identify exploited vulnerabilities and confirm remediation has been completed.

ISO Attestations

Validate ISO 27001 or equivalent certifications that demonstrate structured information security management practices.

Regulatory Compliance

Confirm the model meets applicable regulatory frameworks including performance claims and data handling obligations relevant to your jurisdiction.

In all cases, evaluation should center on understanding the specific security controls implemented within and around the model not just the vendor's claims.

SECURITY TESTING

Model Security Testing

Security testing for AI models goes beyond traditional software testing as it requires probing the model's reasoning, memory, and response patterns against deliberately adversarial conditions.

1 Adversarial Prompt & Data Injection

Test using maliciously crafted prompts or manipulated input data designed to alter model behavior, trigger misclassification, or cause unintended outputs. Evaluate resilience against prompt injection and jailbreak techniques.

2 Sensitive Information Extraction

Assess whether the model can be coerced into revealing sensitive information including confidential training data, system prompts, or internal parameters through targeted query patterns.

3 Reverse-Engineering Resistance

Evaluate whether repeated querying can reconstruct model internals or expose proprietary training data. This is especially critical for models trained on sensitive organizational datasets where intellectual property exposure is a material risk.

CONTROLS EVALUATION

Model Security Controls Evaluation

Output Safety & Compliance

Evaluate whether the model produces harmful, offensive, or policy-violating responses under both normal and stress conditions. Validate the presence and effectiveness of content filtering layers, output moderation pipelines, and alignment mechanisms against organizational expectations and legal requirements.

Rate Limiting & Abuse Prevention

Restricting the frequency of API requests is a critical but often overlooked control. Rate limiting mitigates prompt chaining attacks, brute-force attempts against model logic, and resource exhaustion scenarios that could degrade availability effectively functioning as a denial-of-service safeguard for AI endpoints.

Key Controls Checklist

- Content filtering on inputs and outputs
- Output moderation pipelines
- Alignment with org policy
- API rate limiting configured
- Prompt chaining prevention
- Denial-of-service resistance
- Logging of flagged responses

INFRASTRUCTURE

Infrastructure and Access Controls

Model security extends beyond the model itself — the infrastructure surrounding it defines who can reach it, under what conditions, and with what level of privilege. These environmental controls are foundational to any security review.

Infrastructure Isolation

Define network boundaries that limit which systems and identities can interact with the model. Segmentation prevents lateral movement in the event of a broader compromise.

Authentication & RBAC

Validate strong authentication mechanisms, role-based access controls, and session management policies that govern model access at a granular level.

API Security

Assess API security controls including token validation, input sanitization, and secure communication protocols across all model-facing endpoints.

Guardrails & Red Teaming

A complete baseline review pairs infrastructure controls with behavioral guardrails and structured red teaming exercises to surface exploitable gaps.

KEY TAKEAWAYS

Summary: Model-Specific Controls

A robust AI model security program requires layered controls from evaluation and testing through to infrastructure hardening and continuous monitoring.

1

Lifecycle Protection

Model-specific controls protect AI models from misuse, manipulation, and unauthorized access throughout their entire operational lifecycle.

2

Deployment-Tailored Evaluation

On-premise, open-source, and vendor-provided models each demand a distinct evaluation approach aligned to their unique risk surfaces and available audit evidence.

3

Adversarial Security Testing

Testing must include adversarial prompt injection, reverse-engineering resistance validation, and content compliance checks to surface exploitable model weaknesses.

4

Access & Rate Controls

Rate limiting and infrastructure isolation are non-negotiable access controls that prevent API abuse, prompt chaining, and denial-of-service scenarios.

5

Integrated Review Process

A complete model security review integrates evaluation findings, behavioral guardrails, and structured red teaming into a unified, repeatable assessment framework.